

[doc. web n. 10029393]
Provision of June 20, 2024
Register of provisions
n. 375 of June 20, 2024

THE GUARANTOR FOR THE PROTECTION OF PERSONAL DATA

IN THE meeting today, attended by
Prof. Pasquale Stanzione, President, Prof.
Ginevra Cerrina Feroni, Vice President, Dr.
Agostino Ghiglia, and Attorney Guido Scorza, members, and
Counsel Fabio Mattei, Secretary General;

HAVING REGARD TO Regulation (EU) 2016/679 of the European Parliament
and of the Council of April 27, 2016, concerning
the protection of natural persons with regard to
the processing of personal data, as well as the free
movement of such data and repealing Directive
95/46/EC, "General Data Protection Regulation" (hereinafter, "Regulation");

HAVING REGARD TO Legislative Decree No. 196 of June 30, 2003, containing
"Code regarding the protection of personal data,
containing provisions for the adaptation
of the national legal system to Regulation (EU)
2016/679 of the European Parliament and of the Council, of
April 27, 2016, concerning the protection of
natural persons with regard to the processing of personal data,
as well as the free movement of such data and repealing Directive 95/46/EC (hereinafter
"Code");

HAVING REGARD TO Regulation No. 1/2019 concerning
internal procedures with external relevance,
aimed at carrying out the tasks and
exercising the powers entrusted to the Guarantor for the
protection of personal data, approved by
Resolution No. 98 of April 4, 2019, published in
G.U. No. 106 of May 8, 2019 and on www.gpdp.it, doc.
web n. 9107633 (hereinafter "Guarantor Regulation
No. 1/2019");

HAVING REGARD TO the documentation on file;

HAVING REGARD TO the observations made by the Secretary
General pursuant to Article 15 of the Guarantor
Regulation No. 1/2000 on the organization and
functioning of the office of the Guarantor for the
protection of personal data, doc. web n. 1098801;

REPORTING Dr. Agostino Ghiglia;

PREAMBLE

1. Introduction.

The Authority has learned from public sources that the
Municipality of Forlì (hereinafter, the "Municipality") had made
available to citizens a software application,
called "Falco – Città protetta",
developed by FMI S.r.l. (hereinafter, "FMI" or the

“Company”), which allowed citizens to send reports to the local Police regarding situations of degradation or that raised a certain level of social alarm, however not to the extent that would require an emergency call to 112. Once a report was received, the personnel of the local Police responsible for viewing the surveillance images from the cameras installed in the municipal territory for urban security purposes could monitor the situation in the specific area concerned by the report and, if necessary, send a patrol on-site to carry out checks, having, moreover, temporarily acquired the GPS position and the phone number of the reporting device.

From an informational page published on the FMI website (<https://www.fmi.fc.it/falco/>), it also appeared that, following the receipt of a report, the local Police could also send drones to the area concerned to carry out the necessary checks.

In relation to the processing of personal data of the interested parties, the Municipality qualified as the data controller, indicating FMI as the data processor (see the information on the processing of personal data published at that time on the institutional website of the Municipality, at the address <https://www.fmi.fc.it/privacy-falco/>

#1651136340326-95cb6497-1535), while FMI qualified in turn as the data controller (see the different information published at that time on the Company’s website, at the address <https://www.fmi.fc.it/privacy-falco/>).

2. The investigative activity.

From the investigative activity initiated by the Office against the Municipality of Forlì, following which the Guarantor adopted provision No. 374 of June 20, 2024 (in www.gpdp.it), to which reference is made in full for the overall reconstruction of the events and the technical characteristics of the “Falco” system, it emerged that the Municipality, as the data controller, had entrusted FMI, as the data processor, with certain operations of processing personal data, within the maintenance and support for the management of the video surveillance systems for access to restricted traffic areas and goods movement detection (see Municipal Council Resolution No. 333/2017), the management of the municipal video surveillance system (see Municipal Council Resolution No. 111 of December 19, 2018), as well as the operation and maintenance of the “Falco” system, within the framework of the “Città Protetta 2020 – 2nd and 3rd phase” project (see Municipal Council Resolution No. 200 of June 23, 2021).

Based on the findings of the investigation initiated against the Municipality, the Office, with a note dated May 10, 2023 (prot. n. 0075080), notified the Company, pursuant to Article 166, paragraph 5, of the Code, of the initiation of the procedure for the adoption of the measures referred to in Article 58, paragraph 2, of the Regulation, for having:

- failed to enter into a data protection agreement with the Municipality, in violation of Article 28, paragraph 3, of the Regulation;
- acted in violation of Article 32 of the Regulation, in relation to the configuration of the access methods to the computer system for managing the

****Reports.****

With the same note, the Company was invited to produce defensive writings or documents to the Guarantor or to request to be heard by the Authority (Article 166, paragraphs 6 and 7, of the Code, as well as Article 18, paragraph 1, of Law No. 689 of November 24, 1981).

In a note dated June 8, 2023 (prot. no. 1216/2023), the Company submitted a defensive memorandum, stating, in particular, that:

“the application has never actually exited the testing phase during which one of the preparatory aspects was precisely the analysis regarding the correct processing of personal data”;

“from the software reporting, it does not appear that the Local Police processed any reports. The local police did not process any data derived from the Falco App for managing reports, precisely because they were awaiting further operational instructions regarding privacy impact. This is also evident from the communication of the Central Operational Section of the Local Police Corps of Forlì, dated July 13, 2022 [...]”;

“[...] the Falco application was reactivated solely for the purpose of testing the further modifications requested by the Municipality [...] after the conclusion of the experimental phase scheduled for 05/31/2022, without proceeding to process the very few data received solely on a voluntary basis and used only to test the functionalities of the application. This further testing phase was then suspended on 07/11/2022 [...]”;

already “on April 26, 2022, the [...] FMI [...] had requested [the] Municipality to ‘be classified as an external data processor pursuant to Article 28 GDPR, with the consequent need to sign the appropriate appointments’”;

with “an email dated June 9, 2022 [...] the Municipality was again urged [...] to sign the appointment as data processor”;

FMI “received the appointment as data processor [...] decided by the Municipality [...] on August 31, 2022, for all services related to city surveillance [...] Regarding the specific Falco system, no further formal developments have been recorded as this application was suspended from 07/11/2022 [...]”;

“[...] however, since the Falco system has been offline since July 2022, the appointment as data processor for the Falco App has never arrived”;

“FMI had anticipated the end of the Falco App testing on 05/31/2022, as explicitly stated in the Privacy Policy”;

“in the FMI email dated June 9, 2022, the Local Police was urgently requested to provide the list of reports to be activated, this is absolutely demonstrative that the app was still in a testing state, since if in a report submission app, the type of reports to be sent has yet to be defined, it is evident that the app is neither ready nor final”;

“in the email dated June 27, 2022, the head of the Local Police Operational Center writes ‘following the agreements made and the modifications made to the Falco application, we request to receive the new version of the operational manual to prepare the checks, controls, and monitoring of the reports made by citizens. All this in anticipation of the training update of the personnel regarding the identification of the names to whom to assign usernames and passwords.’ This highlights the following circumstances: [...] before the release of the FALCO system in its final version, the Local Police should have provided FMI with the names of the individual users who were to access the system, which until then was not

possible due to internal organizational reasons within the Local Police and the need to identify who, among the available agents, could be interested in managing Falco”;

“with an email dated June 30, 2022 [...] the head of the Operational Center provided the list of agents to FMI, enabling us to create the nominal users for managing the Falco system”;

“until June 30, 2022, the testing of the Falco app, because it is in a testing phase as some functionalities of the app were not yet mature or even realized, the Local Police used a generic user intended for the testing phase. Before entering actual operation, all Local Police agents would have had their personal user; the generic user would have been permanently deleted with the conclusion of the testing phase”;

“through an email on Thursday, July 7, 2022 [...] the new manual of the Falco system was sent to the head of the Local Police Operational Center of Forlì, which confirmed the realization of the requested modifications in the meantime, thus extending the testing phase at least until that date”;

“on July 11, 2022 (two working days after the sending of the manual), the Municipality [...] ordered FMI to suspend Falco, and FMI complied on the same day”;

therefore, “the users had not been configured until June 30 because the Municipality had not provided the names to be activated for internal organizational reasons and, in any case, being in a testing phase, for the verification of functionalities, a generic user was necessary for the purpose of simplifying bug fixing”;

“the test user was indeed generic, but it would have been deleted when the app was ready and put into actual use.”

3. ****Outcome of the investigative activity.****

3.1 ****The processing of personal data carried out within the framework of the “Falco” project.****

At the conclusion of the investigation, as reconstructed above, it emerged that, within the so-called “Falco” project, FMI has created an IT system consisting of a component of the type “Web on centralized server” and, on the user side, a specific software application for mobile devices, which the Municipality, in its capacity as data controller, processing, has made available to citizens (see note prot. n. 0083196/2022 of July 18, 2022, in the records of the independent but connected procedure initiated against the Municipality). The software application called “Falco” allowed users to verify their presence in an area under video surveillance by the Municipality, as well as to send reports regarding possible situations of degradation or generic potential risk - not such as to necessitate an emergency call - highlighting for the local Police operators, responsible for viewing the surveillance images, the specific footage transmitted by the camera present at the location subject to reporting.

As for the server-side application of the Falco system, it was made available to the Local Police for tracking all anonymized reports sent via the aforementioned application, in order to identify which areas had more or fewer reports over time, facilitating the analysis of the Local Police Command regarding the areas of the municipal territory that required greater monitoring. It was only possible to temporarily trace (for seven days) the phone number associated with the geographical coordinates of the report and the so-called timestamp, to allow the Operational Centers to possibly contact the user who made the report. After seven days, the phone number associated with the coordinates was deleted from the archives, with only the static GPS coordinates of the report and the timestamp when it was made remaining available for statistical purposes.

On the temporal aspect: the “Falco” application was made available in the online stores “Google Play Store” on December 20, 2021, and “Apple Store” on January 26, 2022, in a version that allowed the user to send a report to the local Police, without the possibility of classifying it with predefined settings; moreover, the user could activate the “keyboard” functionality of the phone preset with the number 112; reports could be voluntarily anonymized by the user, pressing a specific button, and were in any case automatically anonymized, by deleting the phone number associated with the static geographical location of the terminal from which the report originated, after seven days from the date of sending it (see report of the FMI under attachment 9 to note prot. 0003022/2023 of January 11, 2023, in the records of the independent but connected procedure initiated against the Municipality); on April 6, 2022, the application was modified as follows: the possibility of specifying the type of report from a

predefined list of items (littering, vandalism and graffiti, traffic accident, domestic violence, bullying, other report) was introduced; the possibility for the user to anonymize their report before the seven-day period was eliminated; the possibility to attach a photograph was introduced, but only if taken anew, without the option to choose a previously saved photo from the user's terminal (ibidem); from the end of April 2022, the application was deactivated, and then reactivated at the beginning of June 2022 (see report of the RPD of the Municipality under attachment 5 to note prot. n. 0083196/2022 of July 18, 2022); on July 11, 2022, following the initiation of the investigation by the Authority, the application was removed from the online stores (see report of the FMI cited) and all reports received were anonymized.

It also emerged that during the normal use of the application, a request was sent to the server every 3.5 seconds containing a so-called digitally signed token, associated with the user's phone number and the static location of the device, which would be "discarded (deleted from the server's memory) after verifying the signature and its expiration date, as its purpose is solely to prevent robots from massively contacting the web service," without it being "ever stored even temporarily in a database, not even in cache or backup"; the static geographical coordinate was "never saved in any case; upon receiving the request to the web service, it was compared with the list of monitored areas (geometric polygons saved in the database) and calculated whether it was within one of them or not. The result of this verification was sent to the app and the coordinates were deleted without ever being stored in any database, neither backup nor transit" (see report of the FMI under attachment 9 to note prot. n. 0003022/2023 of January 11, 2023).

Thus summarized the main characteristics of the Falco system, it is noted that the FMI, acting as the data processor on behalf of the Municipality, also in the more general context of managing the municipal video surveillance system and the video devices for controlling access to the ZTL, violated certain provisions of the Regulation, as illustrated below.

3.2 The failure to define the relationships with the data controller

Pursuant to Article 28, paragraph 3, of the Regulation, "processing by a processor shall be governed by a contract or other legal act under Union or Member State law, which binds the processor to the controller, which stipulates the subject matter and duration of the processing, the nature and purpose of the processing, the type of personal data and the categories...

of the art, the costs of implementation and the nature, scope, context and purposes of the processing as well as the risks of varying likelihood and severity for the rights and freedoms of natural persons, the controller and the processor shall implement appropriate technical and organizational measures to ensure a level of security appropriate to the risk".

In this context, it is essential that both the data controller and the data processor assess the risks associated with the processing activities and implement measures that are commensurate with those risks. The measures may include, but are not limited to, pseudonymization and encryption of personal data, the ability to ensure the ongoing confidentiality, integrity, availability and resilience of processing systems and services, the ability to restore the availability and access to personal data in a timely manner in the event of a physical or technical incident, and a process for regularly testing, assessing and evaluating the effectiveness of technical and organizational measures for ensuring the security of the processing.

3.4 Data breach notification

According to Article 33 of the Regulation, in the event of a personal data breach, the controller shall notify the supervisory authority competent for the controller without undue delay and, where feasible, not later than 72 hours after having become aware of it, unless the personal data breach is unlikely to result in a risk to the rights and freedoms of natural persons.

The notification must include, at a minimum, the nature of the personal data breach, the categories and approximate number of data subjects concerned, the categories and approximate number of personal data records concerned, the name and contact details of the data protection officer or other contact point where more information can be obtained, the likely consequences of the personal data breach, and the measures taken or proposed to be taken by the controller to address the personal data

breach, including, where appropriate, measures to mitigate its possible adverse effects.

3.5 Rights of the data subjects

The Regulation establishes several rights for data subjects, including the right to access their personal data (Article 15), the right to rectification (Article 16), the right to erasure (Article 17), the right to restriction of processing (Article 18), the right to data portability (Article 20), and the right to object (Article 21).

Data subjects have the right to obtain from the controller confirmation as to whether or not personal data concerning them are being processed, and, where that is the case, access to the personal data and information related to the processing. They also have the right to request the rectification of inaccurate personal data concerning them without undue delay and to have incomplete personal data completed.

In the case of a request for erasure, the controller must erase personal data without undue delay when one of the grounds for erasure set out in Article 17 applies.

The rights of data subjects must be respected and facilitated by the controller and the processor, and appropriate procedures must be in place to ensure that these rights can be exercised effectively.

4. Conclusion

In light of the above, it is evident that the obligations set forth in the Regulation have not been fully complied with by the parties involved. The failure to establish a written contract regarding data processing, as required by Article 28, and the lack of appropriate security measures and breach notification procedures constitute significant violations of the Regulation.

It is imperative that the necessary steps are taken to rectify these issues promptly to ensure compliance with the Regulation and to protect the rights and freedoms of data subjects.

the art and the costs of implementation, as well as the nature, object, context, and purposes of the processing, as well as the risk of varying probability and severity for the rights and freedoms of natural persons, the data controller and the data processor implement appropriate technical and organizational measures to ensure a level of security appropriate to the risk [...] (par. 1) and that “in assessing the adequate level of security, particular account is taken of the risks presented by the processing that arise in particular from the destruction, loss, alteration, unauthorized disclosure, or accidental or unlawful access to personal data transmitted, stored, or otherwise processed” (par. 2) (see Recital 83 of the Regulation).

From the documentation acquired in the separate but connected proceedings initiated against the Municipality, it appears that the local police operators of the Municipality, “in the absence of personal credentials for consulting the reports made by users, lacking a specific service provision from the Deputy Commander [...]”, accessed the data collected through the Falco application “using the generic password provided by FMI”, thus not having specific and personal authentication credentials to access the IT system (see note from the local police of the Municipality dated July 13, 2022, in the records).

Considering the nature, object, context, and purposes of the processing, which involved the acquisition and management of reports made by users, with the collection of personal data related to the reporter, such as the phone number and the location of the device, it is believed that the aforementioned modes of access to the IT system are not adequate from a security standpoint (see provision of June 10, 2021, no. 236, web doc no. 9685947).

The use of non-nominal accounts by multiple subjects indeed prevents attributing actions performed in an IT system to a specific subject, to the detriment, even for the data controller and the data processor, who are effectively deprived of the ability to control the actions of subjects operating under their authority. Furthermore, when a non-nominal account, such as the one in question, is used by multiple subjects, situations may arise where there is inconsistency between the authorization profiles assigned and the actual operational needs for managing the systems, thus making it possible for an unauthorized subject to operate, in the absence of a specific will of the data controller or the data processor, within the systems and processing services (see provision of April 4, 2019, no. 83, web doc

no. 9101974; January 14, 2021, no. 4, web doc no. 9582744).

Moreover, the use of “authentication credentials exclusively used by subjects operating under their authority or that of the data processor” in the previous regulatory regime was expressly provided as a minimum security measure that all data controllers were required to adopt (pursuant to the technical regulations referred to in Annex B to the Code, in the text prior to the amendments made by Legislative Decree no. 101/2018), the violation of which also resulted in the application of a criminal sanction (see art. 169 of the Code, in the text prior to the amendments made by Legislative Decree no. 101/2018).

In this regard, it is irrelevant what the Company stated in its defense memorandum concerning the circumstance that the application was in a testing phase, since, as emerged in the separate but connected proceedings initiated against the Municipality, the “Falco” application was made available in online stores “Google Play Store” on December 20, 2021, and “Apple Store” on January 26, 2022, and was therefore usable by users for the purpose of submitting reports. Nor is it relevant that the local police of the Municipality declared that they had not actually followed up on the reports, as the personal data of the reporting users were acquired and processed in any case, regardless of the initiatives taken by the Municipality regarding the reported facts.

In light of the above considerations, given the modes of access to the IT system for managing reports, with the characteristics described above, it must be concluded that the Company, acting as the data processor on behalf of the Municipality (in relation to which a separate proceeding has been initiated), violated art. 32 of the Regulation.

4. Conclusions.

In light of the evaluations mentioned above, it is noted that the statements made by the data processor during the investigation – the truthfulness of which may be subject to accountability under art. 168 of the Code – although deserving of consideration, do not allow for overcoming the objections notified by the Office with the initiation of the proceedings and are insufficient to allow for the archiving of the present proceedings, as none of the cases provided for by art. 11 of the Garante Regulation no. 1/2019 apply.

Therefore, the preliminary evaluations of the Office are confirmed, and the illegality of the processing of personal data carried out by the Company is noted, for having processed personal data in violation of arts. 28, par. 3, and 32 of the Regulation.

That being said, considering that:

although the Municipality and FMI had not entered into a data protection agreement, FMI is a single-member limited liability company with complete public participation, whose ownership is nonetheless traceable to the Municipalities belonging to the Union of Municipalities of Romagna Forlivese, among

to the Municipality of Forlì; furthermore, the parties had nonetheless signed a service contract, having at least generally defined the subject matter regulated and the duration of the processing, the nature and purpose of the processing, the type of personal data, and the categories of data subjects (cf. art. 83, par. 2, lett. a), of the Regulation); the processing concerned a limited number of data subjects compared to the total number of residents in the Municipality (approximately 116,726), given that, as stated by the Municipality during the separate but connected proceeding, the reports received since the first experimental activation (April 2022), including the numerous tests and functionality checks carried out by FMI during the verification of the various versions of the application, amounted to n. 568, while from the date of reactivation (June 8, 2022) n. 86 reports were received, for a total of n. 654 reports, including those for testing purposes only (cf. art. 83, par. 2, lett. a), of the Regulation); the violations are of a negligent nature (cf. art. 83, par. 2, lett. b), of the Regulation); there are no previous relevant violations committed by the Company (art. 83, par. 2, lett. e), of the Regulation); the Company has offered good cooperation with the Authority during the investigation (art. 83, par. 2, lett. f), of the Regulation); the processing did not involve personal data belonging to special categories (see art. 9 of the Regulation), however, it must be considered that the video surveillance systems, installed on public roads for the protection of urban security, may involve the processing of personal data related to

crimes referred to in art. 10 of the Regulation, and that, regarding the Falco system, it could not be completely ruled out, due to the reports submitted by citizens, the processing of personal data related to crimes referred to in art. 10 of the Regulation (cf. art. 83, par. 2, lett. g), of the Regulation), the Company had nonetheless taken action with the Municipality to urge the signing of a data protection agreement (art. 83, par. 2, lett. k), of the Regulation); the violation concerning the security of the processing was also due to the delay with which the Municipality indicated to the Company the names of the subjects authorized to access the system (art. 83, par. 2, lett. k), of the Regulation), the circumstances of the specific case lead to qualify it as a "minor violation," pursuant to art. 83, par. 2, and cons. 148 of the Regulation, as well as the "Guidelines on the application and setting of administrative fines for the purposes of Regulation (EU) No. 2016/679," adopted by the Article 29 Working Party on October 3, 2017, WP 253, and endorsed by the European Data Protection Board with "Endorsement 1/2018" of May 25, 2018. In light of all the above, and the overall terms of the matter at hand, it is therefore deemed sufficient to admonish the Company for the violation of the aforementioned provisions, pursuant to art. 58, par. 2, lett. b), of the Regulation (cf. also cons. 148 of the Regulation). In this context, considering, in any case, that the conduct has exhausted its effects, given that the video devices in question have been uninstalled, the conditions for the adoption of further corrective measures under art. 58, par. 2, of the Regulation do not exist. Finally, it is noted that the conditions referred to in art. 17 of Regulation No. 1/2019 concerning internal procedures with external relevance, aimed at carrying out the tasks and exercising the powers delegated to the Guarantor, are met. ALL OF THE ABOVE HAVING BEEN STATED, THE GUARANTOR a) declares, pursuant to art. 57, par. 1, lett. f), of the Regulation, the unlawfulness of the processing of personal data carried out by FMI S.r.l., represented by the pro-tempore legal representative, with registered office at Piazza Saffi, 8 – 47121 Forlì (FC), C.F. 03981210408, for violation of arts. 28, par. 3, and 32 of the Regulation, as stated in the reasoning; b) pursuant to art. 58, par. 2, lett. b) of the Regulation, admonishes FMI S.r.l., as the data controller in question, for having violated arts. 28, par. 3, and 32 of the Regulation, as described above; c) believes that the conditions referred to in art. 17 of Regulation No. 1/2019 concerning internal procedures with external relevance, aimed at carrying out the tasks and exercising the powers delegated to the Guarantor, are met. Pursuant to arts. 78 of the Regulation, 152 of the Code, and 10 of Legislative Decree No. 150/2011, an appeal against this decision may be lodged before the ordinary judicial authority, under penalty of inadmissibility, within thirty days from the date of notification of the decision itself or within sixty days if the appellant resides abroad. Rome, June 20, 2024 THE PRESIDENT Stanzione THE REPORTER Ghiglia THE SECRETARY GENERAL Mattei